

TEAM SPLIT

Team Member 1 – Frontend & Dashboard (Norman)

Main components owned:

- User Interface / Dashboard
- part of Reporting & Fix Recommendation Module (presentation layer)

Responsibilities:

- build the app UI
- input form for localhost URL + repo path
- findings table/cards
- detail view for each issue
- summary counts, severity badges, export/report screen

Recommended additions (pending team confirmation):

- **human-in-the-loop screens:** a scope gate on the input form (localhost-only URL plus an "I own or am authorized to test this app" confirmation), triage controls on each finding (confirm / reject / escalate, with a reason required to reject or escalate), and a fix approval step for proposed diffs (available only after a finding is confirmed; the UI never applies or merges fixes itself)
- **provisional data contract:** build against a provisional finding schema and API contract until Team 6 finalizes theirs; route all API calls through one adapter file, log missing fields or endpoints as questions for Team 6, and agree on one severity scale with Team 4 (critical / high / medium / low / info)
- **untrusted content handling:** render code snippets, console output, and page text captured from the scanned app as plain text only, never as HTML; mask exposed secrets in the UI and in exports
- **scan progress view:** show each module (runtime, static, security, compliance) as queued / running / done / failed; a failed module must never display as "0 issues"
- **evidence and verification status:** show evidence first (file and lines with snippet, or URL with captured output) and mark unverified "hypothesis" findings distinctly from confirmed ones

- **report coverage:** the export includes a coverage section (each module completed / failed / skipped) and each finding's review decision, with undecided findings labelled pending
- **open decisions:** confirm the tech stack and export formats with the team (proposed defaults: React + TypeScript + Vite; JSON and Markdown, with PDF via print)

Team Member 2 – Runtime / Browser Agent (Anvith)

Main components owned:

- Crawler / Runtime Inspector
- part of Input / Target Connector for localhost connection

Responsibilities:

- connect to the running localhost web app
- crawl pages and flows
- inspect forms, links, auth flows
- capture console errors, network failures, broken pages
- send runtime findings to backend

Team Member 3 – Static Code Analysis (Jaimin)

Main components owned:

- Static Code Analyzer
- part of Input / Target Connector for source code ingestion

Responsibilities:

- read the source code repo
- parse frontend/backend files
- detect memory leak patterns
- detect bad code smells and architecture issues
- identify missing files/pages in codebase

Team Member 4 – Security Analysis

Main components owned:

- Security Analysis Engine

Responsibilities:

- build security rule checks
- detect XSS, CSRF, weak auth/session handling
- check CORS/security headers/config issues
- scan for exposed secrets
- check dependency vulnerabilities
- assign severity to security findings

Team Member 5 – Compliance & Website Requirements

Main components owned:

- Compliance / Website Requirement Checker

Responsibilities:

- check for privacy policy
- check for terms of service
- check for cookie consent / legal pages
- check for contact/about pages
- verify required website trust/compliance elements
- produce compliance findings

Team Member 6 – Backend / Agent Orchestration Lead

Main components owned:

- Agent Orchestrator
- Knowledge Base / Rules Engine
- Reporting & Fix Recommendation Module (backend logic)
- Optional Auto-Fix / PR Generator

Responsibilities:

- coordinate all agents/modules
- define shared finding schema
- merge runtime, code, security, and compliance results
- prioritize and deduplicate findings
- generate final report + fix suggestions

- handle backend APIs and overall integration